Information Security Policy

Policy owner: Chief Information Security Officer. Version 5.0, effective February 1, 2025. Applies to all employees, contractors and systems of Acme Corporation.

1. Data Classification

Acme classifies information into four levels: Public, Internal, Confidential and Restricted. Customer data and employee personal data are always Restricted. Restricted data may only be stored in approved production systems and may never be copied to personal devices.

2. Passwords and Authentication

Passwords must be at least fourteen (14) characters long. Multi-factor authentication is required for every company system that supports it, including email, source control and the VPN. Passwords are not rotated on a schedule; they must be changed immediately when a compromise is suspected.

3. Devices

Company laptops must use full-disk encryption, automatic screen lock after five (5) minutes of inactivity and the managed endpoint protection agent. Lost or stolen devices must be reported to the IT service desk within four (4) hours.

4. Access Control

Access is granted on a least-privilege basis and reviewed every quarter by the system owner. Access for departing employees is revoked on their last working day.

5. Incident Reporting

Employees must report any suspected security incident to security@acme.example within one (1) hour of noticing it. The security team classifies incidents by severity and leads the response.

6. Training

All employees complete security awareness training when they join and every year after that. Employees who fail a simulated phishing test complete a short refresher course within fourteen (14) days.

7. Vendors

A vendor that will process Confidential or Restricted data must pass a security review before a contract is signed. The review is repeated every two (2) years.

8. Exceptions

Exceptions to this policy require written approval from the Chief Information Security Officer and expire after twelve (12) months.